CISO vs Business: Межа компромісу (Кейси для рольової гри)

Кейс 1: Shadow AI: Витік персональних даних (PII) перед раундом інвестицій

🏢 Про компанію:

«PayStream» — FinTech-стартап (150 осіб), що розробляє платформу для міжнародних B2B-платежів. Завтра о 10:00 — презентація інвесторам Series B ($20 млн), від якої залежить виживання компанії.

⚠ Ситуація:

Сьогодні вранці під час перевірки алертів з'ясувалося, що DLP-система ще місяць тому зафіксувала систематичне завантаження коду та даних у публічні AI-чатботи. Розробники вставляли фрагменти вихідного коду нового платіжного ядра та тестовий дамп БД: 12 000 записів клієнтів з ЄС (ПІБ, імейли, історії транзакцій). Оскільки алерт було переглянуто лише сьогодні, формальний відлік 72 годин за GDPR для повідомлення регулятора вже під загрозою. В інвестиційній угоді є пункт про відсутність нерозкритих інцидентів.

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Локалізація витоку та впровадження системного захисту.	• Негайно відкликати скомпрометовані API-ключі з коду та ініціювати запит на видалення даних до AI-провайдера. • Впровадити корпоративний тариф AI з підписаним DPA та	• Погодитися на подальше використання публічних безкоштовних AI-сервісів без DPA. • Приховати факт витоку персональних даних від внутрішньої комісії з ризиків.

Роль	Основне завдання	Ключові цілі	Червоні лінії
		вимкненим навчанням моделей.	
CEO	Успішне закриття раунду інвестицій без порушення закону.	• Провести презентацію інвесторам за графіком. • Оформити розкриття ризиків (disclosure schedule) у договірних документах із планом усунення (Remediation Plan).	• Підписати юридичну гарантію про «абсолютну відсутність інцидентів безпеки» в угоді. • Відкласти розкриття інциденту інвесторам до моменту отримання коштів на рахунок.
CTO	Збереження швидкості розробки та команди.	• Отримати бюджет та підключити корпоративний AI-інструмент протягом 48 годин. • Провести ротацію секретів у кодовому репозиторії без зупинки CI/CD.	• Повністю заборонити розробникам використання будь-яких ШІ-інструментів. • Змусити команду переписувати скомпрометований модуль з нуля вручну.
DPO	Мінімізація штрафів GDPR та юридичних ризиків.	• Підготувати термінове повідомлення регулятору GDPR та оцінити ризик для суб'єктів даних. • Розробити та ввести в дію Політику допустимого використання ШІ (Acceptable Use Policy).	• Відкласти повідомлення регулятора GDPR на 5 днів до підписання інвестиційної угоди. • Обмежитися лише усним попередженням розробників без офіційної кваліфікації інциденту.
PR Director	Захист репутації та контроль інформаційного поля.	• Підготувати антикризовий Q&A для клієнтів та підтримки на випадок виходу інформації у ЗМІ.	• Опублікувати спростування витоку в ЗМІ до завершення розслідування.

Роль	Основне завдання	Ключові цілі	Червоні лінії
		• Сфокусувати комунікацію на швидкому переході на Enterprise AI з гарантіями захисту.	• Звинуватити розробників у публічній заяві компанії.

💡 **Best Practices:**

- Витік PII в публічну LLM — це порушення принципів мінімізації даних та Privacy by Design. Відлік 72 годин за GDPR починається з моменту, коли компанія дізналася про інцидент, але затримка з переглядом алертів DLP є додатковим ризиком комплаєнсу.
- Повна заборона ШІ спричиняє Shadow IT. Правильний компроміс: корпоративний тариф із Data Processing Agreement , вимкненим навчанням моделей та ротацією скомпрометованих секретів.
- Приховування суттєвого інциденту від інвесторів створює ризик скасування угоди та позовів про шахрайство. Контрольоване розкриття — єдиний легальний шлях.

Кейс 2: Атака на ланцюг постачання (Third-Party Risk)

🏢 Про компанію:

«UaCart» — національний маркетплейс (50 000 замовлень/добу). Завтра стартує річний розпродаж із подвійним навантаженням.

⚠ Ситуація:

SaaS-провайдер логістики перестав відповідати. Неофіційно відомо про Ransomware у їхній інфраструктурі. Ваші системи підключені до них через API з постійними токенами. Провайдер по телефону переконує, що це тимчасовий збій, і просить не відключати API. Пропускна здатність вашого резервного ручного відвантаження становить лише 15 000 замовлень/добу (30% від норми).

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Ізоляція мережі за Zero Trust та запобігання бічному руху.	• Негайно відкликати API-токени провайдера та запустити перевірку на наявність бічного руху (lateral movement). • Перевести SOC та системи моніторингу в посилений режим (Defcon 2).	• Залишити API-з'єднання активним «на довірі» до усних запевнень провайдера. • Відкласти відкликання токенів до моменту отримання офіційного листа про злам.
CEO	Забезпечення безперервності бізнесу (BCP) та мінімізація збитків.	• Перевести обробку на резервну схему та скоригувати графік розпродажу. • Продовжити прийом замовлень на сайті із прозорим попередженням про затримку доставки.	• Повністю зупинити роботу маркетплейсу та прийом замовлень більше ніж на 24 години. • Опублікувати заяву, що «UaCart зламано» (коли компрометація сталася у підрядника).
Head of Operations	Логістика та відвантаження в обмежених умовах.	• Запустити ручну обробку замовлень за власними локальними копіями накладних. • Встановити 3-годинний дедлайн провайдеру, після чого переключити обсяги на альтернативних логістів.	• Вимагати від CISO залишити API відкритим попри виявлений ризик компрометації. • Передавати файли з базами адресатів через особисті месенджери чи незахищені хмари.
DPO	Фіксація порушень SLA та збереження страхового покриття.	• Повідомити страхову компанію в межах 24 годин (вимога полісу). • Зафіксувати порушення SLA з боку провайдера та	• Відкласти повідомлення страховика до повного з'ясування обставин • Підписати мирову угоду з провайдером із зняттям із

Роль	Основне завдання	Ключові цілі	Червоні лінії
		підготувати претензійну документацію.	нього юридичної відповідальності.
PR Director	Управління очікуваннями клієнтів та партнерів.	• Опублікувати чесний статус: тимчасова затримка доставки через збій у партнера, власні системи захищені. • Забезпечити регулярне оновлення статусу виконання замовлень щогодини.	• Опублікувати оманливу заяву про «планові технічні роботи на сайті UaCart». • Мовчати та ігнорувати скарги клієнтів понад 6 годин.

💡 Best Practices:

- При підозрі на компрометацію підрядника діє принцип Zero Trust: API-токени відкликаються негайно, не чекаючи офіційного підтвердження, після чого проводиться пошук lateral movement.
- Безперервність бізнесу базується на розрахунку пропускної здатності та наявності логістичних альтернатив, а не на роботі з ризикованим підрядником.
- Страхування кібербезпеки вимагає строгого дотримання строків повідомлення

Кейс 3: Недоступний адміністратор та підозріла активність (SkyShield)

🏢 Про компанію:

«SkyShield» — defense-tech стартап (60 осіб), який розробляє софт наведення для розвідувальних дронів ЗСУ. Реліз оновлення — через 36 годин.

⚠ Ситуація:

Головний DevOps-інженер Андрій (єдиний носій root-доступу) перебуває у зоні без зв'язку під час виконання завдань. CISO має IAM-права на відкликання сервісних токенів, але не має root-паролів. SIEM зафіксувала масове викачування телеметрії польотів із сервісного токена Андрія з закордонної IP. Це може бути його автоматичний скрипт або компрометація. Потрібно перевірити цілісність збірки та ключів підпису. Повний аудит цілісності коду та ключів займає 48 годин

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Запобігання витоку військових даних та збереження доказів.	• Скористатися IAM-правами для негайного відкликання токена, зняття логів. • Провести аудит цілісності збірки софту та ключів підпису перед релізом.	• Дозволити невідомій IP-адресі завершити завантаження бази даних для «перевірки файлів». • Проігнорувати перевірку цілісності підпису коду заради дотримання дедлайну 36 годин.
CEO	Виконання контракту з Міноборони та розбудова системності.	• Офіційно попередити замовника про можливе коригування графіку через перевірку безпеки. • Затвердити бюджет на впровадження системи PAM та бекап-адміністрування	• Приховати факт підозрілої активності від військового замовника. • Наказати розробникам обходити перевірки безпеки задля швидкого релізу.
CTO	Відновлення інфраструктури та технічна перевірка.	• Ініціювати процедуру відновлення root-доступу через ліцензійні механізми хмарного провайдера. • Розгорнути чисту середу збірки з перевіреного	• Використовувати незадокументовані бекдори для відновлення контролю над серверами. • Звинуватити відсутнього інженера у зраді без проведення форензики.

Роль	Основне завдання	Ключові цілі	Червоні лінії
		репозиторію та призначити другого адміна.	
Compliance Officer	Дотримання режиму держконтракту та регуляторних вимог	• Задокументувати хронологію подій та повідомити CERT-UA/СБУ відповідно до умов контракту. • Оформити документальне підтвердження обставин відсутності інженера.	• Підробити цифровий підпис або облікові дані відсутнього інженера для скидання паролів. • Затримати повідомлення про підозру до завершення внутрішнього аналізу

💡 **Best Practices:**

- Будь-яка підозріла активність у критичній інфраструктурі вимагає негайної ізоляції з попереднім збереженням доказів.
- У оборонному софті цілісність збірки та підпис коду мають вищий пріоритет за дедлайн: випуск скомпрометованого оновлення може коштувати життів.
- Управління привілейованим доступом (PAM), Break-glass акаунти та відсутність єдиної точки відмови мають вирішуватися архітектурно до настання криз.

Кейс 4: Legacy-бекдор під час угоди M&A на $45M

🏢 **Про компанію:**

«PayTech Studio» — український стартап у сфері розробки платіжних рішень (120 людей). За 48 годин має відбутися підписання угоди про продаж компанії міжнародному гіганту «FinTech Core Global» за $45 млн. У стартапу є боргові зобов'язання на $5 млн із дедлайном виплати через 3 дні. Якщо угода зірветься або відкладеться — стартап негайно стає банкрутом. Вартість повного рефакторингу $1 млн, знижка при розкриті $11 млн.

⚠ Ситуація:

За 12 годин до передачі передпродажного звіту покупцю внутрішня команда безпеки під час передпродажного аудиту виявила бекдор від APT-групи у застарілому модулі автентифікації. Через нього протягом 2 років міг відбуватися витік зашифрованих токенів. Повна локалізація вимагає 7 днів. Дилема: чесно вказати це у звіті зараз (ризик зниження оцінки на 20-30% або перенесення угоди) чи спробувати деплоїти тимчасове “костильне рішення” до підписання без оновлення документів.

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Чистота інфраструктури та прозорість технічних ризиків.	• Зафіксувати факт компрометації, розпочати форензику та ізолювати застарілий модуль. • Внести дані про бекдор до технічного звіту та розробити Remediation Plan.	• Підписати декларацію про повну відсутність прихованих загроз в інфраструктурі. • Надати вказівку видалити логи аудиту до передачі звіту Покупцю.
CEO	Збереження угоди M&A та фінансового майбутнього.	• Закрити угоду із прозорим висвітленням ризиків через спеціальний інструмент гарантій. • Запропонувати Покупцю створення Escrow-рахунку для фінансування рефакторингу після угоди.	• Приховати факт бекдору від Покупця до моменту перерахування коштів. • Повністю скасувати угоду M&A без спроби домовитися про Escrow.
Investment Lead	Захист оцінки компанії та мінімізація зниження ціни.	• Переконати Покупця, що виявлений ризик є контрольованим і не компрометує інтелектуальну власність.	• Погодитися на зниження оцінки компанії більше ніж на 35% без технічного обґрунтування.

Роль	Основне завдання	Ключові цілі	Червоні лінії
		• Утримувати зниження оцінки компанії в межах не більше 5–10%.	• Схиляти технічну команду до фальсифікації передпродажного звіту.
CTO	Технічна локалізація та стабільність продукту.	• Встановити компенсаційні контролі (WAF + ротація токенів) протягом 12 годин без зупинки платформи. • Затвердити графік повного переписання ядра автентифікації у наступному кварталі.	• Повністю відключити модуль аутентифікації платіжної системи на 7 днів під час підписання угоди. • Почати рефакторинг ядра без узгодження із бізнес-календарем угоди.
Compliance Officer	Юридична чистота угоди та мінімізація судових позовів.	• Внести гарантійні застереження (Indemnities) та план усунення до остаточного договору. • Оцінити обов'язки щодо повідомлення регуляторів (GDPR/PCI DSS) від моменту виявлення.	• Відкласти повідомлення про витік персональних даних на строк понад 72 години з моменту виявлення. • Підписати акт приймання-передачі коду без юридичного застереження про бекдор.

💡 Best Practices:

- Свідоме приховування критичного бекдору під час M&A Due Diligence створює високий ризик визнання угоди недійсною та позовів про шахрайство (M&A Fraud).
- Конструктивний бізнес-компроміс: включення інциденту до Disclosure Schedule та виділення частини коштів на Escrow-рахунок до завершення Remediation Plan.
- Технічний борг (Legacy) у критичних вузлах автентифікації вимагає постійного моніторингу та завчасної заміни до моменту виходу на угоду.

Кейс 5: Кібервимагання під час Disaster Recovery у медичній мережі

🏢 Про компанію:

«CloudHosp» — приватна мережа медичних центрів (понад 2 млн медичних карт пацієнтів, у тому числі військовослужбовців).

⚠ Ситуація:

Внаслідок ракетного обстрілу пошкоджено ЦОД у Києві. Під час аварійного переключення на резервну хмару у Франкфурті розробники через відкритий порт на скомпрометованому маршрутизаторі запустили реплікацію через незашифрований канал. Зловмисники перехопили 100 000 карток і вимагають $2 млн викупу протягом 12 годин, погрожуючи публікацією даних військових. Лікарі вимагають негайного доступу до карт для проведення ургентних операцій.

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Захист чутливих даних (PHI) та зупинка витоку.	• Негайно закрити вразливий порт, підняти зашифрований тунель та перевірити чистоту бекапів. • Забезпечити категоричну відмову від виплати викупу шантажистам.	• Дозволити подальшу реплікацію через незашифрований канал заради швидкості. • Приховати факт витоку медичних даних від правоохоронних органів та СБУ.
CEO	Захист життя пацієнтів та збереження діяльності мережі.	• Забезпечити відновлення доступу лікарів до критичних даних протягом 2 годин через перевірені резервні схеми.	• Наказати виплатити викупи з криптогаманця компанії без консультацій із правоохоронцями. • Повністю заблокувати роботу всіх медичних центрів понад 6 годин.

Роль	Основне завдання	Ключові цілі	Червоні лінії
		• Не допустити зупинки екстрених медичних операцій у клініках.	
Medical Director	Забезпечення безперервності лікування.	• Впровадити тимчасовий паперовий регламент та захищений режим зчитування даних. • Забезпечити безперебійне проведення ургентних хірургічних втручань.	• Створити неузгоджені локальні бази пацієнтів у незахищених Google-Таблицях чи Excel. • Скасувати ургентні операції через відсутність електронного доступу до системи.
Head of Cloud Infrastructure	Технічне відновлення та цілісність даних.	• Підняти ізольований зашифрований VPN-канал та відновити системи з останнього бекапу. • Провести верифікацію втрат даних за останні години та запустити їх узгоджене відновлення.	• Запустити відновлення з бекапу без попередньої перевірки його цілісності та відсутності закладок. • Видалити логи аварійного переключення DR під час проведення робіт.
DPO	Комплаєнс та взаємодія із регуляторами.	• Повідомити Уповноваженого ВРУ з прав людини, СБУ та МОЗ про витік у встановлені строки. • Оцінити правові ризики та штрафні санкції згідно із законодавством про захист персональних даних.	• Приховати факт компрометації даних військовослужбовців від спеціальних служб. • Погодитися на вимоги хакерів щодо приватної виплати коштів.

💡 Best Practices:

- Виплата викупу зловмисникам не гарантує повернення даних і створює високі юридичні ризики (аж до відповідальності за фінансування тероризму).
- Disaster Recovery Plan (DRP) повинен включати обов'язкову перевірку захищеності каналів реплікації (Security by Design) та верифікацію чистоти резервних копій.
- Для медичних даних (PHI) під час аварій розробляється BCP із контрольованими процедурами екстреного доступу (Break-glass access) без створення Shadow IT.

Кейс 6: Deepfake-атака на фінансовий департамент агрохолдингу

🏢 Про компанію:

«AgroTrade Group» — агрохолдинг (виторг >$300 млн). Готується масштабне постачання палива для посівної кампанії.

⚠ Ситуація:

Під час термінового Zoom-дзвінка «CEO» (real-time Deepfake) доручив CFO перерахувати $3.5 млн за паливо на новий рахунок. Платіж пройшов. Через годину справжній CEO скасував вказівку. Рахунок шахраїв тимчасово заморожено банку-відкликачем на 48 годин. Для повернення коштів банк вимагає заяву від компанії до Кіберполіції. Проте подання заяви ініціює AML-перевірку європейського банку, що заморозить транзитний рахунок закупівлі палива на 48–72 години та поставить під загрозу графік посівної. Ціна простою $500.000 за день затримки.

Матриця ролей та цілей:

Роль	Основне завдання	Ключові цілі	Червоні лінії
CISO	Форензика атаки та впровадження антифрод-контролів.	• Провести форензику Zoom-сесії, з'ясувати вектор проникнення та ізолювати вектор атаки. • Впровадити обов'язковий Out-of-Band (позамережевий) підтверджувальний регламент для платежів від $100k.	• Скласти звіт із класифікацією втрати $3.5 млн як «помилки оператора» без технічного аналізу. • Залишити регламенти погодження платежів топ-менеджменту без змін.
CEO	Фінансова стабільність та проведення посівної.	• Забезпечити постачання палива для посівної протягом 48 годин за резервною схемою. • Затвердити план розблокування коштів спільно з банківським комплаєнсом.	• Звинуватити CFO у змові та звільнити його без проведення розслідування. • Закупити паливо за готівкові кошти з неофіційних джерел без перевірки ІБ.
CFO	Відновлення ліквідності та запуск процедури Recall.	• Подати офіційну заяву на відкликання платежу та надати докази шахрайства банку. • Оформити тимчасове кредитування для покриття дефіциту палива на час перевірки.	• Провести повторний некоректний платіж без проходження перевірки. • Приховати факт фінансових збитків від ревізійної комісії холдингу.
Head of Supply Chain	Матеріально-технічне забезпечення посівної.	• Укласти угоду з альтернативним постачальником палива з відстрочкою платежу.	• Зупинити вихід техніки в поля понад 48 годин. • Вимагати від CISO припинити розслідування

Роль	Основне завдання	Ключові цілі	Червоні лінії
		• Забезпечити вихід сільськогосподарської техніки в поля за графіком.	заради негайного розблокування рахунку.
Chief Legal Officer	Врегулювання відносин з банком та моніторингом.	• Надати банку та Кіберполіції повний пакет документів для точкового розблокування транзитного рахунку. • Забезпечити юридичну чистоту процедури повернення коштів.	• Подати недостовірні свідчення чи фіктивні контракти банківським установам. • Порушити вимоги законодавства щодо протидії відмиванню коштів

💡 Best Practices:

- Атаки класу Executive Impersonation неможливо зупинити лише візуальним контролем: потрібен строгий регламент підтвердження (двофакторне підтвердження іншим каналом).
- Взаємодія з банківським комплаєнсом під час процедури Recall вимагає точкової юридичної роботи та наявності резервних фінансових ліній.
- Форензика інциденту та кримінальне провадження є обов'язковими для повернення коштів та активації кіберстрахування.